

위험관리 개요



학습내용

- 위험관리 개념
- 위험관리 프로세스

학습목표

- 위험관리에 대한 **기본개념**을 설명할 수 있다.
- 프로세스 별 단계의 **특징**을 설명할 수 있다.

위험관리 개념

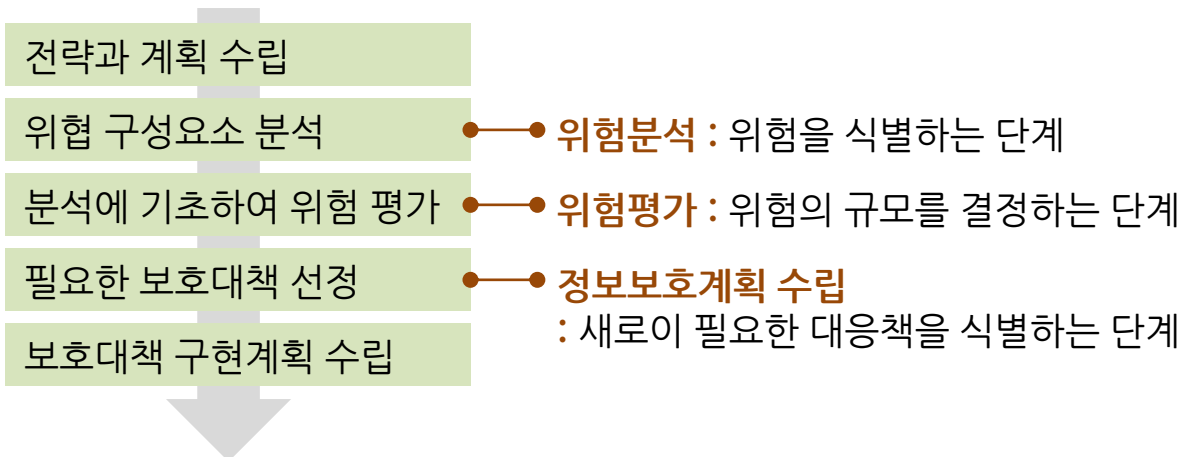
1. 위험관리(Risk Management) 정의

- 과거 초기의 위험분석은 물리적 위협에만 적용이 되었음
- 일반적으로 위협의 발생 가능성에 따른 잠재적인 손실을 계산하는 것으로 사용되었음
- 이것을 보험 산업에서 채택하여 위협의 개념을 정립하였음
- 이 개념이 IT 분야에 적용되었음

1) 위험관리(Risk Management)

조직의 자산에 대한 위협을 감수할 수 있는 수준으로 유지하기 위하여 자산에 대한 위협을 분석하고 이러한 위협으로부터 자산을 보호하기 위한 비용 대비 효과적인 보호대책을 마련하는 일련의 과정

2) 위험관리의 과정



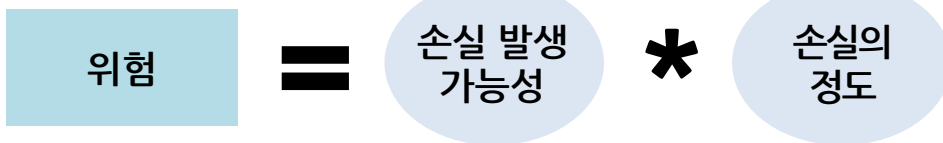
🔑 위험관리 개념

2. 위험의 개념

$$\text{Risk} = f(\text{자산, 위협, 취약성})$$

$$\text{위험의 크기} = \text{발생가능성} * \text{손실}$$

[예] 주사위를 던져 6이 나오면 600원을 얻는다고 가정을 해 보죠.
6이 나올 확률은 1/6이기 때문에 $1/6 * 600\text{원} = 100\text{원}$ 이므로
기댓값은 100원이 됨



- 위험은 손실을 미치는 사건이 발생할 가능성과 그때 발생하는 손실의 정도의 곱으로 평가될 수 있음

위험관리 개념

2. 위험의 개념

자산 (Asset)

- 정의 : 조직이 보호해야 할 대상
- 종류 : 정보, 하드웨어, 소프트웨어, 시설 등
- 특징 : 관련 인력, 기업 이미지 등의 무형자산 포함

취약성 (Vulnerability)

- 정의 : 자산의 잠재적 속성이나 처한 환경
- 위협의 이용 대상 : 관리적, 물리적, 기술적 약점

위협 (Threat)

- 정의 : 자산에 손실을 초래할 수 있는 원치 않는 사건의 잠재적인 원인이나 행위자

위험관리 개념

2. 위험의 개념

1) 위험관리 측면에서의 취약성과 위협이란?

(1) 취약성(Vulnerability)

- 정의 : 자산이 가지고 있는 약점
 - 취약성 자체로 인해서는 위험을 발생시키지 않음

(2) 위협(Threat)

- 정의 : 외부의 공격 가능성

취약성 + 위협 → '위험' 발생

위험

정보자산의 취약한 부분에 위협요소가 발생하여 자산의 손실, 손상을 유발하는 잠재성

정보보호대책

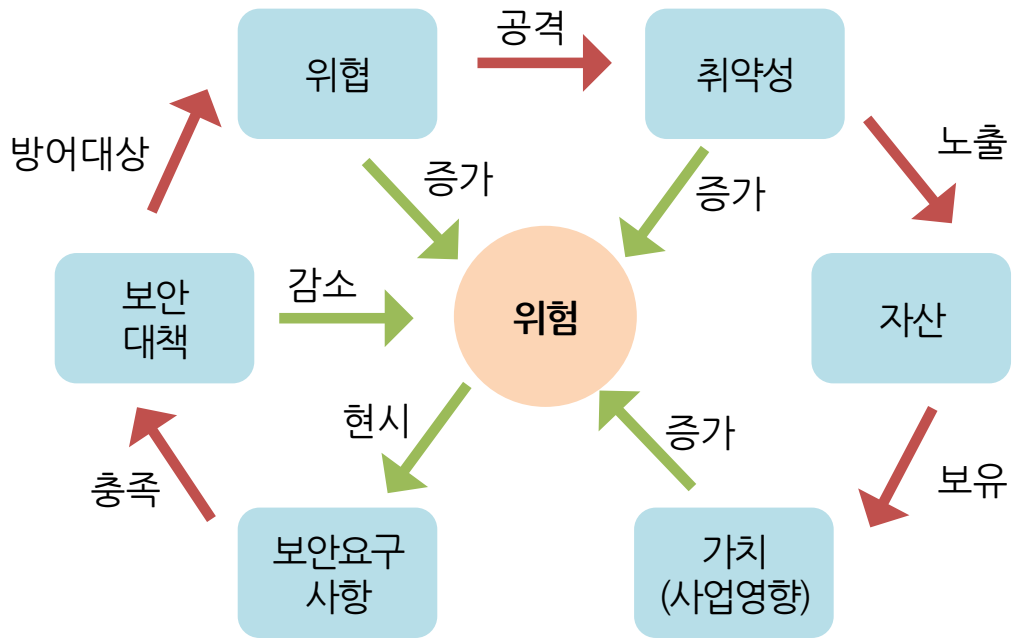
위협에 대응하여 자산을 보호하기 위한 관리적, 물리적, 기술적 대책

잔여위험

정보보호대책을 구현한 후 남아있는 위험

🔑 위험관리 개념

2. 위험의 개념



정보보호대책

위협을 방어함으로써 위험을 감소시키는 것

체계적인 위험분석 과정 없이 보호대책 수립할 경우?

→취약성과 위협에 대한 우선순위가 설정되지 못해서 **불필요하거나 과도한 투자** 발생

→보호대책을 수립하였음에도 불구하고 **위협에 대처하지 못하는 경우** 발생

위험관리 개념

3. 위험분석 방법론

과학적이고 정형적인 과정으로 위험을 알아내고 측정하려는
방법을 제시함

방법론 자체는 전 세계적으로 아주 다양한 방법론들이 존재함

- 위험분석을 수행하고자 하는 대상 조직 및 특징, 요구사항, 수행기간 등 상황과 여건을 고려하여 적절한 방법론을 선택하여 적용함

3. 위험분석 방법론

1) 계량화 여부에 따른 분류

(1) 정량적 기법

- 정의 : 손실 및 위험의 크기를 금액으로 나타내는 기법
- 종류 : 과거자료 접근법, 수학기식 접근법, 확률분포 추정법 등

[‘위험’을 정량적으로 표현하는 예시]

- ✓ 조직의 연간 예상 손실액(Annual Loss Expectancy)
- ✓ 특정 사건에 대한 위험의 정도
→ ‘해킹에 따른 위험이 높다.’ 등으로 표현될 수도 있음

① 장점

- 정량화된 자료의 사용으로 비용 효과 분석 및 예산 계획이 용이함
- 수리적 방법의 사용으로 계산이 논리적임

② 단점

- 정확한 정량화 수치를 구하기가 어려움
- 수리계산에 많은 시간과 노력이 필요함

3. 위험분석 방법론

1) 계량화 여부에 따른 분류

(2) 정성적 기법

- 정의 : 분석자의 경험 및 지식에 기초한 위험분석 방법
→ 손실크기를 측정할 수 없어서 위험을 구간 및 기술변수
(예: H:3, M:2, L:1)로 표현함
- 종류 : 델파이법, 시나리오법, 순위결정법 등

① 장점

- 정량화하기 어려운 정보의 평가에 용이함
- 용어의 이해가 쉬움
- 분석의 소요시간이 짧음

② 단점

- 주관적 판단의 남용 여지가 있음
- 비용-효과 분석이 어려움

3. 위험분석 방법론

2) 접근방식에 따른 분류

위험분석 및 평가 대상 조직의 보안요구사항, 가용자원
(전문 인력, 기간, 예산 등), 규모 등을 고려하여 적절한 접근방식 선택

(1) 기준선 접근법(Baseline Approach)

- 모든 시스템에 대하여 표준화된 보안대책의 세트를 체크리스트 형태로 제공하는 방식
- 모든 시스템에 대하여 보호의 기본수준을 정하고 이를 달성하기 위하여 일련의 보호대책을 선택함

① 장점

- 시간과 비용이 많이 들지 않고 모든 조직에서 **기본적으로 필요한 보호대책의 선택** 가능

② 단점

- 조직의 특성을 고려하지 않았기 때문에 조직 내에 부서별로 **적정 보안수준보다도 높게 혹은 낮게 보안통제**를 적용

3. 위험분석 방법론

2) 접근방식에 따른 분류

(2) 전문가 판단법(Informal Approach)

- 정형화된 방법을 사용하지 않고 **전문가의 지식과 경험**에 따라서 위험을 분석하는 방법

① 장점

- 작은 조직에 **비용-효과적임**

② 단점

- 위험을 제대로 평가하기 어려움**
- 보호대책의 선택 및 소요비용을 **합리적으로 도출하기 어려움**
- 계속적으로 반복되는 보안관리의 **보안감사 및 사후관리가 제한됨**

3. 위험분석 방법론

2) 접근방식에 따른 분류

(3) 상세위험 접근법(Detailed Risk Approach)

- 자산의 가치를 측정하고 자산에 대한 **위협의 정도**와 취약성을 분석하여 **위협의 정도**를 결정하는 방법
- 조직의 자산 및 보안요구사항을 구체적으로 분석
→ 가장 적절한 대책을 수립!

① 장점

- 자산, 위협, 취약성의 목록이 작성 및 검토되었으므로 이후 변경이 발생하였을 때 조직 내에 적절한 **보안수준 마련**이 가능함

② 단점

- **전문적인 지식**이 필요함
- **시간**과 **노력**이 많이 소요됨

3. 위험분석 방법론

2) 접근방식에 따른 분류

(4) 복합적 접근법(Combined Approach)

- 조직활동에 대해 필수적이고 위험이 높은 시스템 식별 방법
 - 식별된 시스템: **상세위험 접근법 적용**
 - 나머지 시스템: **기준선 접근법 적용**

① 장점

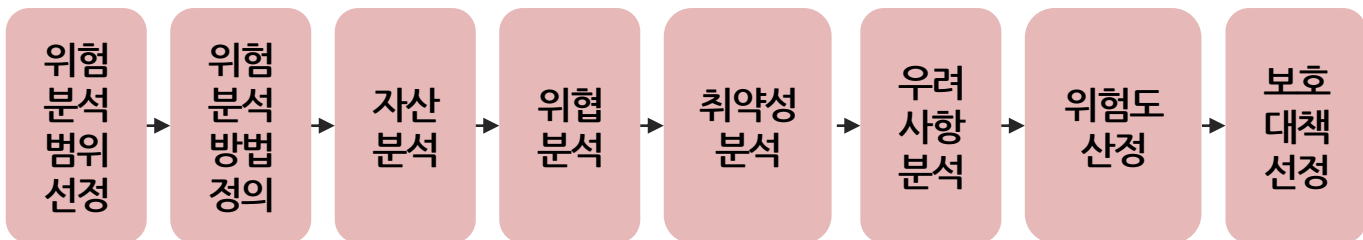
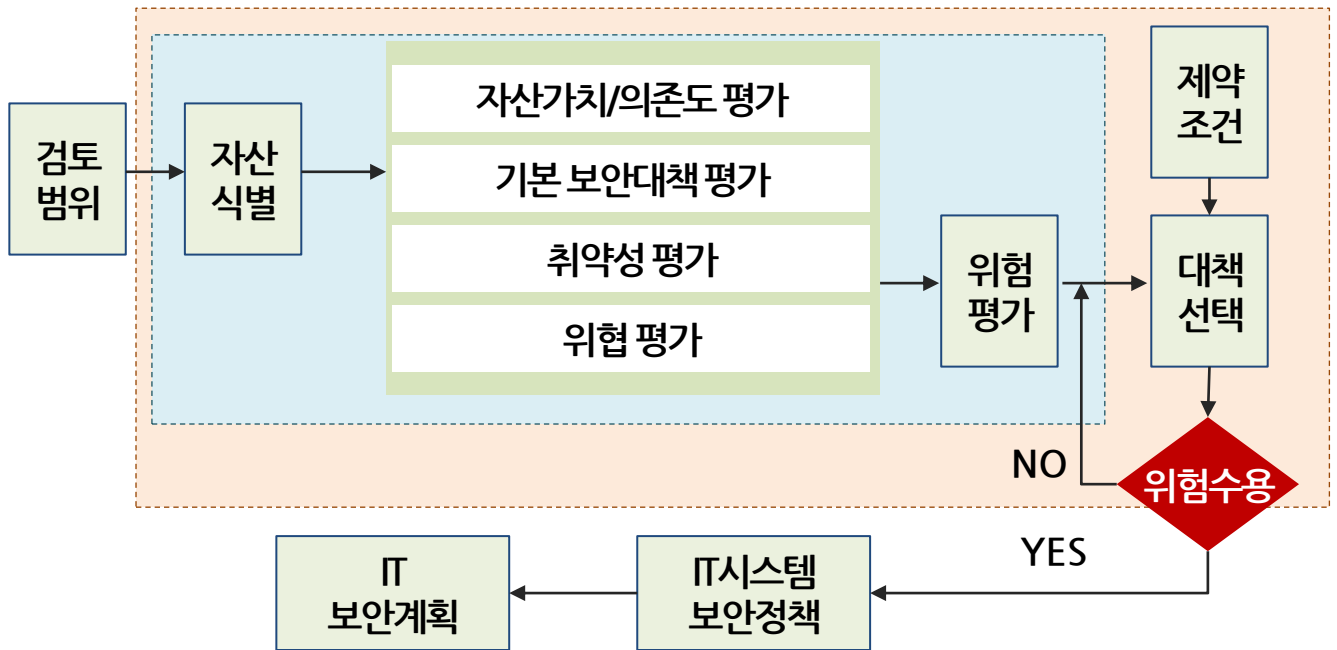
- 보안전략을 빠르게 구축할 수 있음
- 상대적으로 시간과 노력을 효율적으로 활용 가능

② 단점

- 필수적이고 위험이 높은 시스템을 잘못 식별하였을 경우
자원의 낭비 발생 가능성이 있음

🔑 위험관리 프로세스

1. 위험관리 단계



위험관리 프로세스

1. 위험관리 단계

1) 위험분석 범위 선정

내용

업무, 조직, 위치, 자산 및 기술적 특성에 따라 위험분석 범위 선정

방법

조직의 사업(서비스)에 영향을 줄 수 있는 핵심자산 (임직원, 정보시스템, 정보, 시설 등 유·무형의 핵심자산) 포함시킴

예

- 주요 서비스(사업) 현황 등
- 주요 정보통신 설비의 목록과 시스템 및 네트워크 구성도
- 기업이 준수해야 할 법적 요구사항 현황, 내부감사 이력 등
- 정책, 지침, 절차, 기록 및 로그 등 주요 문서 목록

위험관리 프로세스

1. 위험관리 단계

2) 위험분석 방법 정의

내용

관리적, 기술적, 물리적, 법적 분야 등 조직의 전 영역에 대한 위험식별 및 평가가 가능하도록 각 영역별 특성을 반영하여 방법 선정

예

- **관리적, 물리적, 법적 분야의 방법론**
: 베이스라인 접근법 적용
- **기술적 분야의 방법론**
: 상세위험분석 또는 복합적 접근법 적용

핵심자산에 대한 기술적 위험분석

상세 위험분석(자산 중요도, 위협, 취약성) 수행

외부 전문가 활용

전문가 별로 위험관리 방법론이 변경되는 것 방지
→ 조직 내 정의된 위험관리방법론에 따라 자문 받음

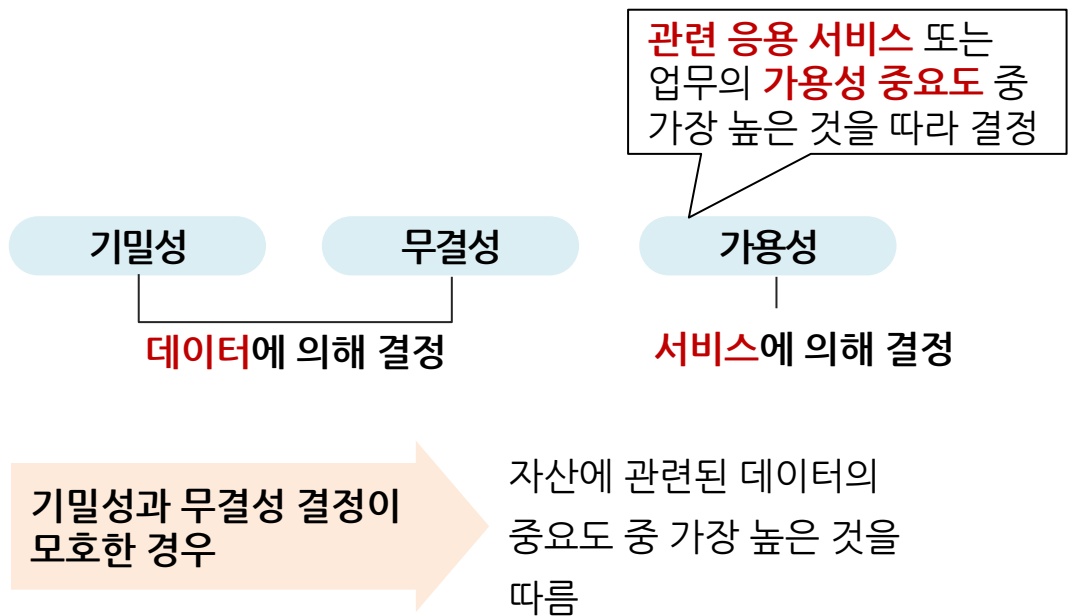
🔑 위험관리 프로세스

1. 위험관리 단계

3) 자산분석

내용

조직의 업무와 연관된 정보 및 정보시스템을 포함하는 정보자산을 식별하고 해당 자산의 **기밀성, 무결성, 가용성**이 상실되었을 때의 결과가 조직에 미칠 수 있는 영향을 고려하여 가치 평가



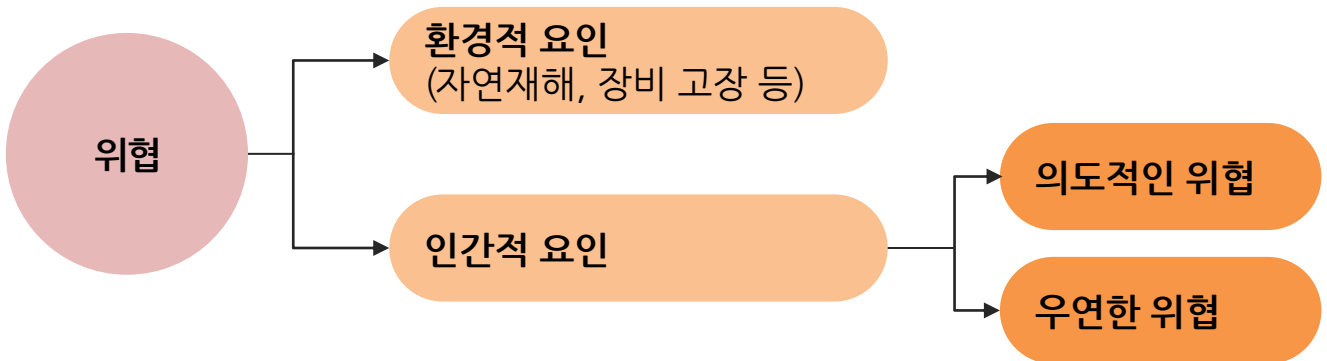
🔑 위험관리 프로세스

1. 위험관리 단계

4) 위험분석

내용

자산에 대한 **위협**의 식별 및 발생 가능성 정도를 인터뷰 또는 실사를 통하여 측정함



- 위협이 발생했다고 반드시 피해가 발생하는 것은 아니며, **‘자산이 그 위협에 취약한지’ ‘그 취약성을 보호할 대책이 있는지’**에 따라 달라지게 됨

많이 발생하는 위협을 중심으로 **담당자 및 책임자가 우려하는 위협**을 추가적으로 고려해보자!

위험관리 프로세스

1. 위험관리 단계

5) 취약성 분석

내용

식별된 위협에 대하여 **자산이 어느 정도 취약한가**를 인터뷰 또는 실사를 통하여 판명함

취약성

- 자산의 잠재적 속성으로서 위협의 이용 대상이 되는 것
- 자산에 취약성이 없다면 위협이 발생해도 손실이 나타나지 않음

방법

특정 위협이 발생할 때 특정 자산에 자산의 가치와 관련하여 **어느 정도의 피해가 발생할 지**를 **취약성, 노출 정도**라는 값으로 나타냄

1. 위험관리 단계

6) 우려사항 분석

내용

위협과 취약성의 구분이 어려운 경우는 **우려사항**이라는 용어의 정의로서 이용 가능

방법

- **자산의 보호 요구사항이 낮을 경우**
: 대책이 없음에도 취약성이 낮다고 평가
- **자산의 가치가 높을 경우**
: 대책이 존재함에도 취약성이 높다고 평가

→ 이러한 경향을 고려하여 위협과 취약성을 통합적으로 평가

예

가능성	설명
높음	어떠한 문제점이 나타날 가능성이 높다.
중간	어떠한 문제점이 어느 정도 나타날 가능성이 있다.
낮음	어떠한 문제점이 나타날 가능성이 거의 없다.

1. 위험관리 단계

7) 위험도 산정

내용

식별된 자산, 위협 및 취약성을 기준으로 위험도를 산출하고 기존의 보호대책을 파악함

방법

해당 정보자산의 가치와 위협 및 취약성의 정도에 따라 기밀성, 무결성, 가용성 손상에 따른 잠재적 손실의 규모 평가

① 정량적 방식

산출방법

자산 A에 대한 위협 T가 연간 발생시킬 수 있는 연간예산손실 =
자산 A의 가치(원) * 위협 T의 연간 발생횟수 * T에 대한 A의 취약성(%)

- 자산의 가치 : 금액
- 위협 : 연간 발생 횟수
- 취약성 : %로 평가

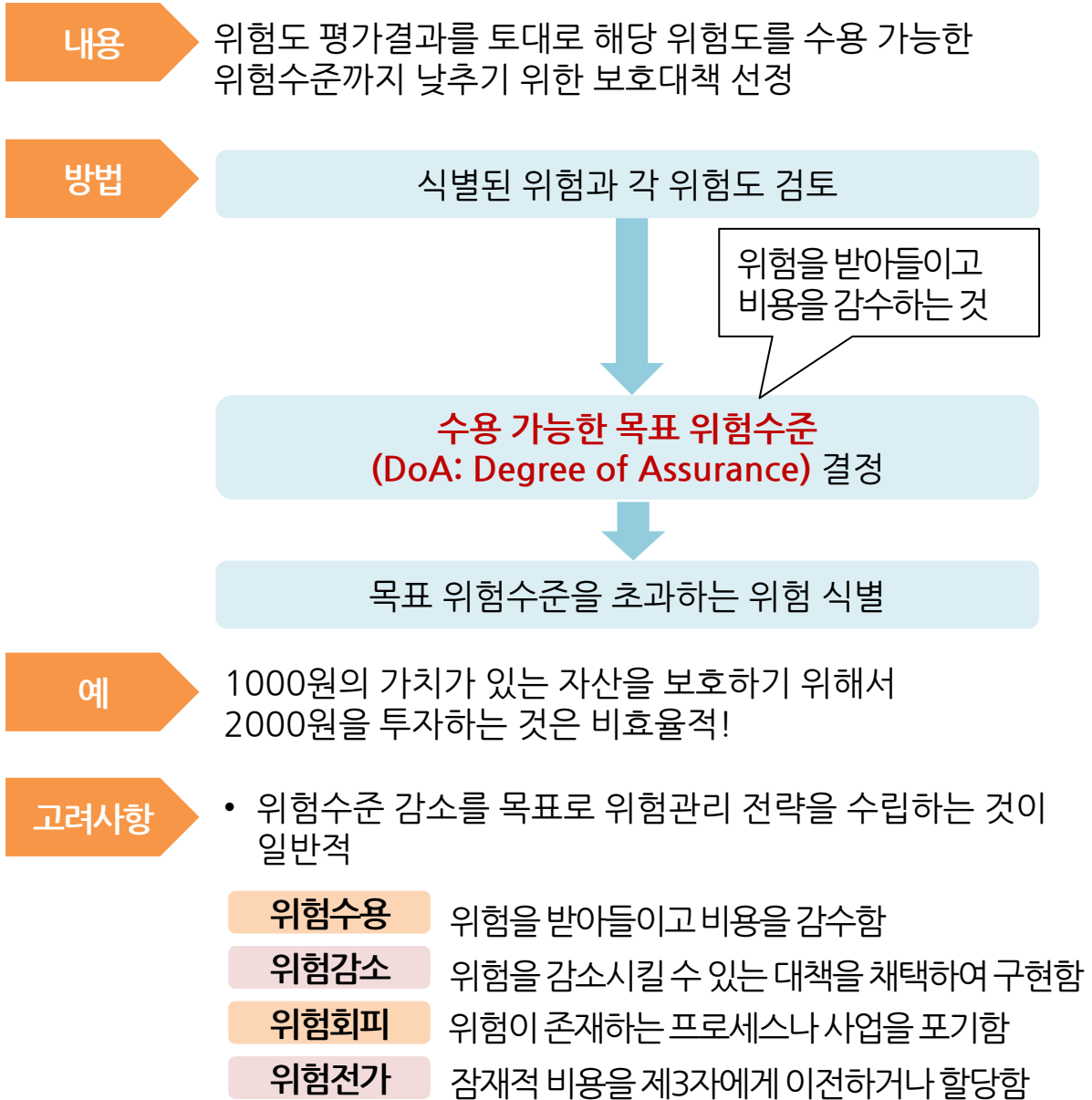
② 정성적 방식

- 산출방법 : 자산, 위협, 취약성의 값을 곱하거나 더함
(방법론에 따라 약간의 차이는 있음)

🔑 위험관리 프로세스

1. 위험관리 단계

8) 보호대책 선정



‘이후의 원활한 운영을 위해 각 단계별로
관련자들의 이해와 동의를 얻는 것이 필수적!’

2. 정보보호 계획 수립

1) 프로젝트 구성

- 위험수준의 감소를 위해 선정한 정보보호대책을 **위험처리의 시급성, 예산 할당, 구현에 요구되는 기간**에 따라 우선순위를 정하고 계획을 수립하여 지속적으로 관리·수행

(1) 유사 대책의 종류

① 즉시 교정 가능한 취약성 제거

- 내용 : 빠른 시간 내에 처리할 수 있는 사항들
- 종류 : 시스템이나 장비의 구성 설정 변경, 파일 등의 권한 변경, 취약한 패스워드 변경 등
- 고려사항 : 변경에 따른 영향 등

② 정책 및 절차 수립

- 내용 : 정책을 우선 수립하고 이를 준수하기 위한 절차를 마련
- 특징 : 다른 업무보다 높은 우선순위를 가짐

‘이후의 원활한 운영을 위해 각 단계별로 **관련자들의 이해와 동의를 얻는 것이 필수적!’**



2. 정보보호 계획 수립

1) 프로젝트 구성

(1) 유사 대책의 종류

③ 분야별 정보보호 시스템 도입 및 관련 교육

- 개별 정보보호 시스템은 수행 관리의 효율성을 위해 네트워크, 서버, PC, 응용 시스템 관련 등으로 분류하여 별도 프로젝트로 설정하고, 각각의 정보보호 시스템 도입에는 관련자 교육이 포함되어야 함

④ 모니터링 및 감사 관련 사항

- 모니터링 및 감사에 필요한 사항(모니터링 감사를 위한 정책, 절차, 책임 설정, 모니터링 또는 감사용 시스템 도입 등) 결정
→ 정보보호 대책 별로 감사하여야 할 사항들을 작성하여
감사 체크리스트에 포함시킴



2. 정보보호 계획 수립

2) 구현 계획 수립

- 프로젝트 별로 예산, 구현 일정, 프로젝트의 세부 내용, 해당 프로젝트 수행에 관한 책임 등이 포함된 **정보보호 계획 수립**

실제 프로젝트를 수행하고 이에 영향을 받게 될 부서들의 책임자 및 실무자가 반드시 참여해야 함

인력 및 자금 지원, 책임의 수용, 구현 일정의 타당성 및 실행 가능성 등을 검토하거나 피드백을 제공해야 실제 구현 가능한 계획이 작성될 수 있음

핵심요약

1. 위험관리 개념

1) 위험관리

- 조직의 자산에 대한 위험을 감수할 수 있는 수준으로 유지하기 위하여 자산에 대한 위험을 분석하고 이러한 위험으로부터 자산을 보호하기 위한 비용 대비 효과적인 보호대책을 마련하는 일련의 과정

2) 전략과 계획을 수립, 위험을 구성하는 요소 분석, 분석에 기초하여 위험을 평가, 필요한 대책을 선정, 보호대책을 구현할 계획 수립 등의 활동 수행

3) 위험분석 방법론

- 위험분석 방법론은 과학적이고 정형적인 과정으로 위험을 알아내고 측정하려는 방법을 제시

4) 접근방식에 따른 위험분석 방법

- 기준선 접근법(Baseline Approach),
전문가 판단법(Informal Approach),
상세위험 접근법(Detailed Risk Approach),
복합적 접근법(Combined Approach) 중 선택적으로 적용

핵심요약

2. 위험관리 프로세스

1) 정보보호 계획 수립의 프로젝트 구성

- 특성과 목적이 유사한 대책들을 하나의 프로젝트로 묶어 구현계획 수립

2) 구현 계획 수립

- 프로젝트 별로 예산, 구현 일정, 프로젝트의 세부 내용, 해당 프로젝트 수행에 관한 책임 등이 포함된 정보보호 계획을 수립

